WORKSHOP · CYBERSECURITY RISK MANAGEMENT

Cybersecurity Risk Management Framework

Identify, assess, treat, accept and monitor cyber risks in a mid-sized organization



Presented by: Lan Anh Chung

Why We Need a Risk Management Framework

The need

- Growing attack surface: cloud, remote work, suppliers
- Limited budget and staff: not everything can be fixed at once
- Ad-hoc, inconsistent decisions without a common yardstick
- Rising regulatory and customer expectations (e.g. GDPR, NIS2, ISO 27001)

Purpose of our solution

- Identify, assess and treat cyber risks in a consistent way
- Prioritize by risk and put resources where they matter most
- Define when a risk is acceptable and who decides
- Balance security with operational efficiency

The cycle: 1 Identify → 2 Assess → 3 Treat → 4 Accept → 5 Monitor, repeated continuously.

Risk Identification: Three Methods Compared

Criterion	Threat Modeling	Vulnerability Assessment	Incident Review
How it works	Attacker's view of architecture and data flows (STRIDE, attack trees)	Automated scans and pen tests, scored with CVSS	Lessons learned from past incidents
Thoroughness: external threats	**High**	**High**	**Medium**
Thoroughness: insider threats	**Medium (abuse cases)**	**Low**	**Medium**
Thoroughness: human error	**Medium**	**Low**	**High**
Finds new, previously unknown risks	**High (proactive)**	**Medium (known only)**	**Low (reactive)**
Practicality / effort	**Labor-intensive**	**Easy to automate**	**Low effort**

Recommendation: vulnerability assessments as the continuous baseline, threat modeling for critical applications and new projects, incident reviews as feedback loop.

Assessment Criteria at a Glance

Level	Likelihood
1	Very rare: less than 1 event in 10 years
2	Rare: about every 3 to 10 years
3	Possible: about every 1 to 3 years
4	Likely: several times per year
5	Almost certain: monthly or more often

Level	Financial	Operations	Reputation / legal
1 Minor	under €10k	under 1 hr outage	noticed internally only
2 Low	€10–50k	1–4 hrs	individual customers affected
3 Medium	€50–250k	4–24 hrs	customer complaints, local media
4 High	€250k–1M	1–3 days	national coverage, customer loss
5 Critical	over €1M	over 3 days	breach notification, fines, existential threat

Score = likelihood × impact (max. 25): Low 1–4 · Medium 5–9 · High 10–16 · Critical 17–25. Overall impact is the highest of the three dimensions. Thresholds are example values, calibrated to revenue and risk appetite.

Prioritization: Matrix vs. Quantitative

Criterion	Risk matrix (qualitative)	ALE / FAIR (quantitative)
How it works	Score on a 5×5 grid; bands Low to Critical	Expected annual loss in euros
Effectiveness	Fast ranking, coarse resolution	Comparison in euros, enables cost-benefit analysis
Usability	Very high: intuitive, executive-friendly	Medium: needs methodological know-how
Data need	Low: expert judgment	High: loss and event data
Effort	Low	High; worthwhile for top risks
Weakness	Subjective; many risks cluster in the middle	False precision when data is thin

QUANTITATIVE EXAMPLE

ALE = SLE × ARO

Annualized Loss Expectancy = Single Loss Expectancy × Annualized Rate of Occurrence

Ransomware (illustrative)
SLE €400,000 × ARO 0.2
= €80,000 per year

Recommendation: hybrid. Matrix for broad initial assessment, ALE or FAIR for top risks before large investments.

Risk Treatment: Mitigation vs. Transfer

Criterion	Risk mitigation	Risk transfer
Cost	Investment plus ongoing operations and staff; scales with scope	Ongoing premiums and deductible; rise with an unfavorable risk profile
Effort	High implementation effort, know-how and project time needed	Quick to conclude, but insurers require baseline controls such as MFA and backups
Long-term effectiveness	Actually lowers the risk; needs upkeep and updates	Covers financial loss only; exclusions and limits; data and reputation damage remain
Side effects on operations	May affect convenience and performance, adds complexity	May create false sense of security; obligations after a claim

SELECTION LOGIC

1. Intolerable and dispensable?
   → **Avoid**
2. Control economical (ROSI > 0)?
   → **Mitigate**
3. Residual risk high with extreme loss?
   → **Transfer**
4. Remainder within tolerance?
   → **Accept**

When Is a Risk Acceptable?

Cost-benefit

If a control costs more than the risk reduction it delivers (ROSI ≤ 0), further mitigation is not economical.

Residual risk

After treatment, the residual risk lies within the defined risk tolerance.

Risk appetite

Executive management knowingly shares the risk. Legal obligations are never acceptable.

Residual score	Decision	Approved by	Expiry / review
1–4 Low	Acceptable	Risk owner (business unit)	Annual review
5–9 Medium	Acceptable with justification	Department head and CISO	Semi-annual review
10–16 High	Only time-limited, with conditions	Executive mgmt / risk committee	Max. 12 months, quarterly
17–25 Critical	Not acceptable: treatment mandatory	Escalation to executive mgmt	Immediate action plan

Documenting and Monitoring Accepted Risks

1

Record

Enter risk, assessment and residual risk in the risk register

2

Justify

Document cost-benefit and the alternatives considered

3

Approve

Risk owner and approver sign off, expiry date is set

4

Monitor

Track key risk indicators and thresholds continuously

5

Reassess

At review or trigger, renew or treat the risk

Mandatory risk register fields

- Risk ID
- Description
- Risk owner
- Inherent score
- Residual score
- Decision
- Approver
- Expiry date
- KRIs / thresholds
- Next review

Triggers for an out-of-cycle review

- New exploit or active exploitation
- Security incident related to the risk
- Changes to systems or business processes
- Audit finding or KRI threshold breach

Monitoring: Automated vs. Periodic

Criterion	Automated monitoring	Periodic assessments and audits
Examples	SIEM, IDS/IPS, EDR, continuous vulnerability scans, threat intelligence feeds	Quarterly risk reviews, internal and external audits, penetration tests, tabletop exercises
Real-time detection	Very good: events visible within minutes	Weak: delay until the next cycle
Detecting new, strategic risks	Limited: only detects what rules and signatures cover	Good: expert judgment captures business and threat changes
Resources	High upfront investment, 24/7 operation, tuning against false positives	Peak effort at intervals, lower fixed cost, needs skilled staff

Recommended hybrid model

Continuous
SIEM, IDS/IPS, EDR

Monthly
Vulnerability and KRI reports

Quarterly
Risk register review

Annually
Audit, pen test, tabletop

An Integrated, Risk-Based Cycle

Identification

Selected
Threat modeling and vulnerability assessment, complemented by incident reviews

Rationale
Proactive and technical, covers multiple risk vectors

Vulnerability Assessment

Assessment

Selected
5×5 risk matrix as standard, ALE or FAIR for top risks

Rationale
Easy to use plus cost-benefit calculation

Risk Matrix

Treatment

Selected
Mitigation first, transfer for residual risk

Rationale
Actually lowers risk and covers extreme cases financially

Mitigation

Acceptance

Selected
Score bands, approval levels, time-limited approvals

Rationale
Traceable, accountable, auditable

Score Bands

Monitoring

Selected
Automated and periodic, tiered by cadence

Rationale
Real-time visibility and strategic overview

Automated Monitoring